

Atalaya

Desarrollo de un asistente para re-valorizar veredictos de sandbox para la priorización de incidentes en un SOC

(centro de operaciones de seguridad)

Iván de Diego Benítez

Tutor: Borja Bordel Sánchez

Grado en Ingeniería de Computadores · ETSISI, Universidad Politécnica de Madrid · septiembre de 2026

01

El problema

Por qué la puntuación del sandbox no basta para ordenar las alertas

EL PROBLEMA

Qué aporta un sandbox al SOC

Un SOC recibe más alertas críticas de las que puede revisar. Cuando la alerta trae un fichero sospechoso, un sandbox como CAPE añade evidencia de lo que ese fichero hace.

Alerta

Un fichero sospechoso en un equipo de la organización.

›

CAPE

Lo ejecuta en una máquina aislada y observa lo que hace.

›

Informe

Firmas, técnicas de ataque, red y una puntuación de 0 a 10.

›

Cola del SOC

¿Qué se mira primero?

La ventaja: el analista decide con lo que la muestra hace, además de con la alerta. No todos los SOC tienen un sandbox, y en los que lo tienen, su puntuación pesa mucho al decidir qué se mira primero.

EL PROBLEMA

CAPE puntúa bien, pero satura

La puntuación de riesgo de CAPE, el malscore, va de 0 a 10. Así se reparte en 48.976 informes reales:



Datos: Avast-CTU, informes públicos de CAPE publicados por Avast y la Universidad Técnica Checa.

EL PROBLEMA

Objetivo y preguntas de investigación

Diseñar, implementar y evaluar un asistente de triaje que re-valore el veredicto de CAPE con señales independientes de su puntuación y entregue al SOC una cola ordenada por urgencia, trazable y accionable.

1	¿Ordena las alertas mejor que la puntuación de CAPE?	**Sí dentro del empate, separando familias no mejora a CAPE**
2	¿Baja los casos sobrevalorados y sube los infravalorados?	**Sí, reordena en los dos sentidos, pero los falsos positivos no se han podido medir**
3	¿La ficha que genera recoge lo que el analista necesita para actuar?	**Con la plantilla, sí: da familia, urgencia, nivel y acción. Falta validarla con analistas**

EL PROBLEMA

Dónde encaja este trabajo

En los trabajos que he revisado, ninguno cubre el tramo completo, del informe del sandbox a una cola ordenada y explicada.

	Parte del informe del sandbox	Ordena la cola del analista
Anomalías en registros Landauer 2023 · LogBERT · LogLLM	✗	✗
Análisis en sandbox Gazdík 2023 · Bouhnine 2024	✓	✗
Priorización en el SOC Rashid 2025 · Hassan 2020	✗	✓
Atalaya este trabajo	✓	✓

02

Lo construido

Arquitectura, motor de decisión y demostración

LO CONSTRUIDO

Seis piezas encadenadas

01	02	03	04	05	06
Lector de CAPE	**Severidad**	**Anomalía**	**Falsos positivos**	**Urgencia**	**Ficha e interfaz**
versiones 2.2 y 2.5	reglas fijas	aprendizaje automático	programado, aún sin efecto	de 0 a 10	plantilla y web

La severidad sale de reglas fijas: la misma muestra da siempre el mismo resultado, y cada punto se puede leer.

La urgencia es esa severidad ajustada por el único componente que aprende de los datos, el detector de anomalía, que la sube como mucho un 20 %.

LO CONSTRUIDO

El motor de severidad

severidad = tipo + firmas + técnicas + notoriedad

3,5 máx.

tipo
ransomware y control remoto arriba, mineros abajo

3,0 máx.

firmas de CAPE
gravedad y número de las firmas

2,5 máx.

técnicas
catálogo MITRE ATT&CK de técnicas de ataque

1,0 máx.

notoriedad
lista propia, a partir de avisos de ciberseguridad de EE. UU. (CISA)

Ejemplo real de la cola, un troyano bancario (Ursnif):

2,50 + 1,98 + 0,60 + 1,00 = 6,08

LO CONSTRUIDO

De severidad a urgencia

$$\text{urgencia} = \text{severidad} \times (1 + 0{,}20 \times \text{anomalía}) \times \text{falsos positivos} \times \text{contexto}$$

364	22.562	22.201	3.849
crítico	**alto**	**medio**	**bajo**
≥ 8,0	6,0 a 8,0	3,0 a 6,0	< 3,0

Los factores de falsos positivos y de contexto están programados, pero en toda la cola evaluada valen 1: al primero le faltan ficheros benignos para ajustarse, y al segundo, datos de la red de la organización.

La puntuación de CAPE no entra en ninguna parte de la fórmula: solo aparece al lado, para comparar.

ANALIZAR UN CASO

Envía un informe de CAPE y obtén el veredicto

Sube el `report.json` de un análisis de sandbox (o usa un ejemplo). Atalaya lo pasa por el pipeline completo —parser → severidad → anomalía → FP → urgencia → síntesis— y devuelve el veredicto re-valorado, con su desglose auditable.

ENTRADA

report.json de CAPE 2.x

Informe a analizar

Ejemplos del dataset Avast-CTU:

njRAT · rat
malscore CAPE 10.0

Emotet · banker
malscore CAPE 10.0

HarHar · coinminer
malscore CAPE 8.9

— o sube tu propio informe —

ELEGIR INFORME…

ningún informe seleccionado

Analizar

La familia/tipo del malware provienen de una etiqueta externa (no del propio informe); por eso los ejemplos la traen. Un informe suelto sin etiqueta se valora solo por su comportamiento observado.

03 Resultados

Qué cambia en la cola y qué no mejora

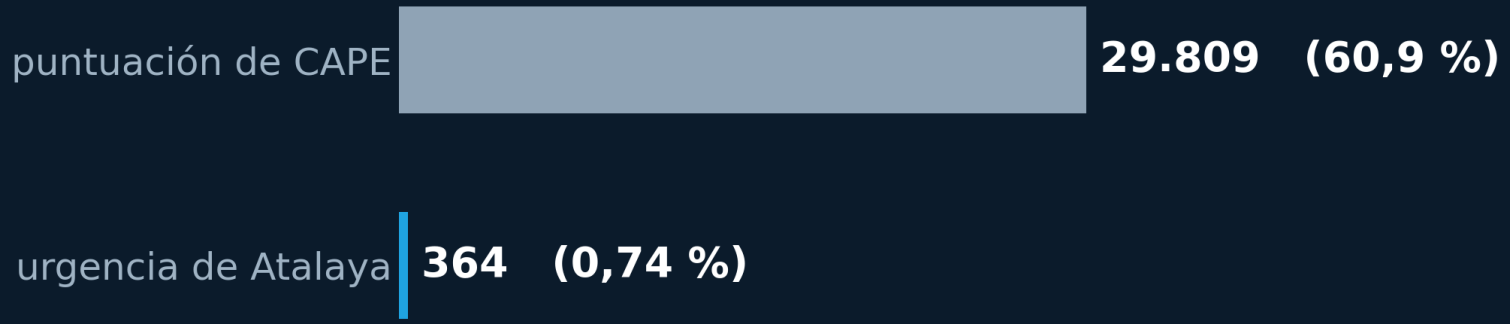
RESULTADOS

Toda la cola, antes y después



RESULTADOS

De 29.809 alertas urgentes a 364



82× menos casos en el nivel crítico.

Con la puntuación de CAPE, cualquier umbral deja arriba las 27.565 empatadas a la vez. Con Atalaya, cada SOC decide cuántas mira primero: con el umbral de 8,0 son 364.

RESULTADOS

Frente a la puntuación de CAPE

¿Quién separa mejor las familias?

0,477

Atalaya
(solo comportamiento)

0,510

CAPE

η^2: 0 si la familia no influye, 1 si solo influye la familia

¿Ordenan igual?

0,807

1 sería el
mismo orden

Spearman

CAPE separa algo mejor las familias.
Atalaya cambia el orden sobre todo dentro del empate.

04 Cierre

Limitaciones, líneas futuras y conclusiones

CIERRE

Limitaciones y líneas futuras

	Limitación	Siguiente paso
1	Una sola fuente de datos (Avast-CTU).	Ajustarlo con los informes reales del propio SOC: casos variados, también benignos.
2	Depende de la etiqueta de familia: menos fiable ante familias nuevas.	Sacar el tipo del propio informe o con un clasificador ligero.
3	El nivel crítico depende del detector de anomalía, evaluado con los mismos datos con los que aprendió.	Probarlo con muestras de otro periodo o de otro SOC.
4	El corrector de falsos positivos no se ha podido medir.	Medirlo con ficheros benignos reales.
5	Ni el orden ni la ficha se han evaluado con analistas.	Evaluarlos con analistas y una rúbrica.
6	No se probó conectado a CAPE en vivo.	Conectarlo a CAPE 2.5: el lector ya está validado con informes reales.

CIERRE

Conclusiones

56,28 %

de la cola que CAPE empataba, ahora ordenada

7 de 7

objetivos cumplidos, dos con matices

Cada posición se explica punto a punto.

La puntuación de CAPE no entra en el cálculo.

No ejecuta muestras y funciona en un portátil o en la nube.

Gracias por su atención

¿Preguntas?

Iván de Diego Benítez · Atalaya

ANEXO

Cómo sale la urgencia del primer caso

Un njRAT con un 10 en CAPE. Atalaya lo pone el primero de la cola.

Tipo: control remoto	**3,00**
Firmas de CAPE (40)	**2,20**
Técnicas de ataque (10)	**1,25**
Notoriedad: está en la lista	**1,00**
Severidad	**7,45**
Anomalía 0,757: sube un 15 %	**× 1,151**
Urgencia	**8,58**

Nivel crítico. Acción que propone: aislar el equipo y escalar con prioridad máxima.

ANEXO

Los cinco primeros de la cola

Puesto	Familia	CAPE	Atalaya	Nivel
1	njRAT	10	**8,58**	crítico
2	njRAT	10	**8,52**	crítico
3	njRAT	10	**8,49**	crítico
4	njRAT	10	**8,48**	crítico
5	njRAT	10	**8,38**	crítico

Los cinco tienen un 10 en CAPE. Atalaya los ordena.

ANEXO

Uno que sube y uno que baja

njRAT

+37.231 puestos

CAPE 3,5 → Atalaya 6,62, alto

Programa de control remoto, de una familia de la lista.

Swisyn

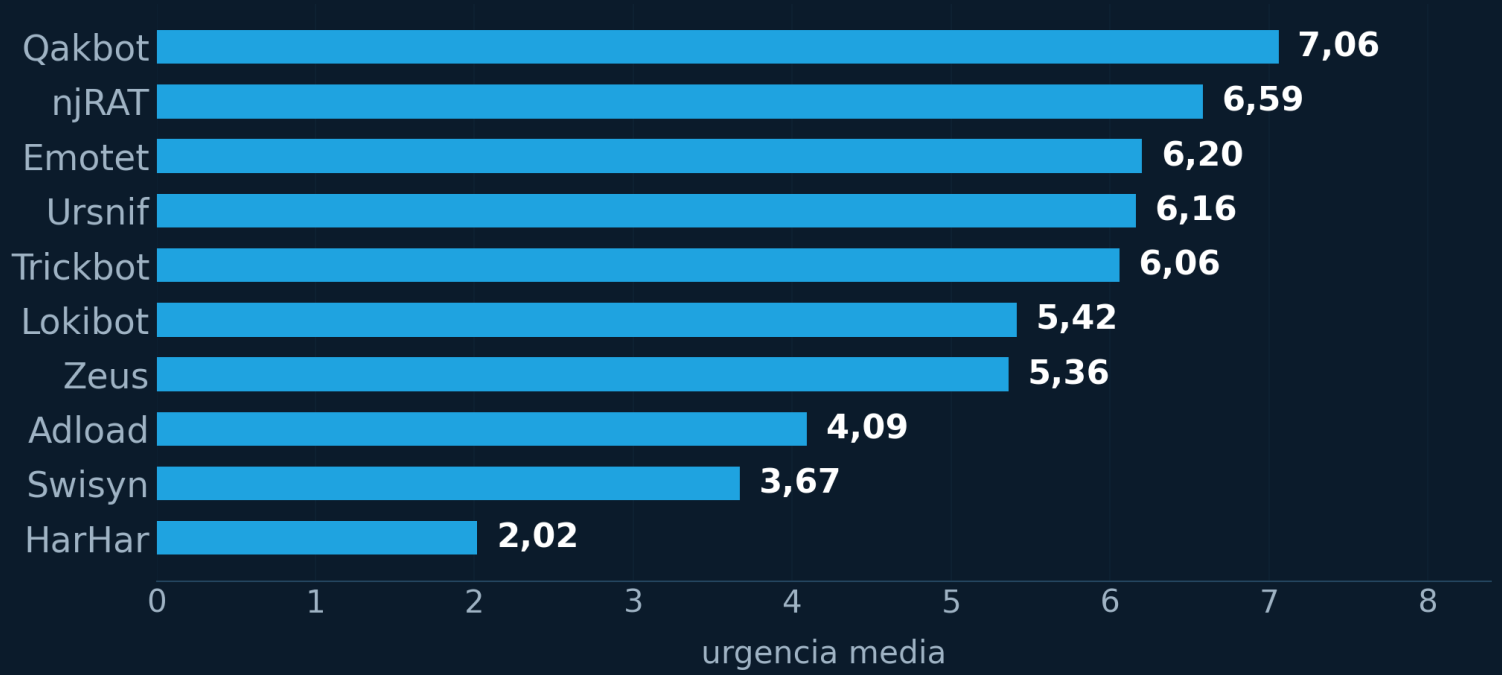
–21.791 puestos

CAPE 10 → Atalaya 4,21, medio

Troyano genérico, de una familia que no está en la lista.

ANEXO

Urgencia media por familia



ANEXO

Los siete objetivos

1	Informes reales de CAPE, con una etiqueta que no salga de su puntuación.	cumplido
2	Un motor de severidad con reglas que se puedan revisar. CAPE separa algo mejor las familias	cumplido
3	Un detector de anomalía y un corrector de falsos positivos. El corrector no se ha podido medir	cumplido
4	Una urgencia de 0 a 10 con cuatro niveles.	cumplido
5	Una ficha para el analista, con plantilla o con modelo de lenguaje.	cumplido
6	Comparar el resultado con la puntuación de CAPE.	cumplido
7	Una API y una web donde se vea de dónde sale cada número.	cumplido

ANEXO

De qué depende el número de críticas

	Críticas
Tal como está	**364**
Sin la anomalía	**0**
Sin la notoriedad	**0**
Con el corte en 7 en vez de 8	**4.163**
Si el detector da por raras el 5 % de las muestras (ahora el 10 %)	**unas 200**
Si da por raras el 15 %	**unas 580**
Entrenando el detector con una mitad y probando con la otra	**se queda el 98 %**

Las 364 son 332 Qakbot, 28 njRAT, 3 Ursnif y 1 Emotet.

ANEXO

Revisión de casos y sensibilidad

REVISIÓN A MANO

57 de 64

casos coherentes

7 con una salvedad explicada, ninguno sin sentido

SI CAMBIO LAS CONSTANTES

0,9887

de parecido, como mínimo, con el orden original

y el 85 % de las 364 primeras sigue arriba